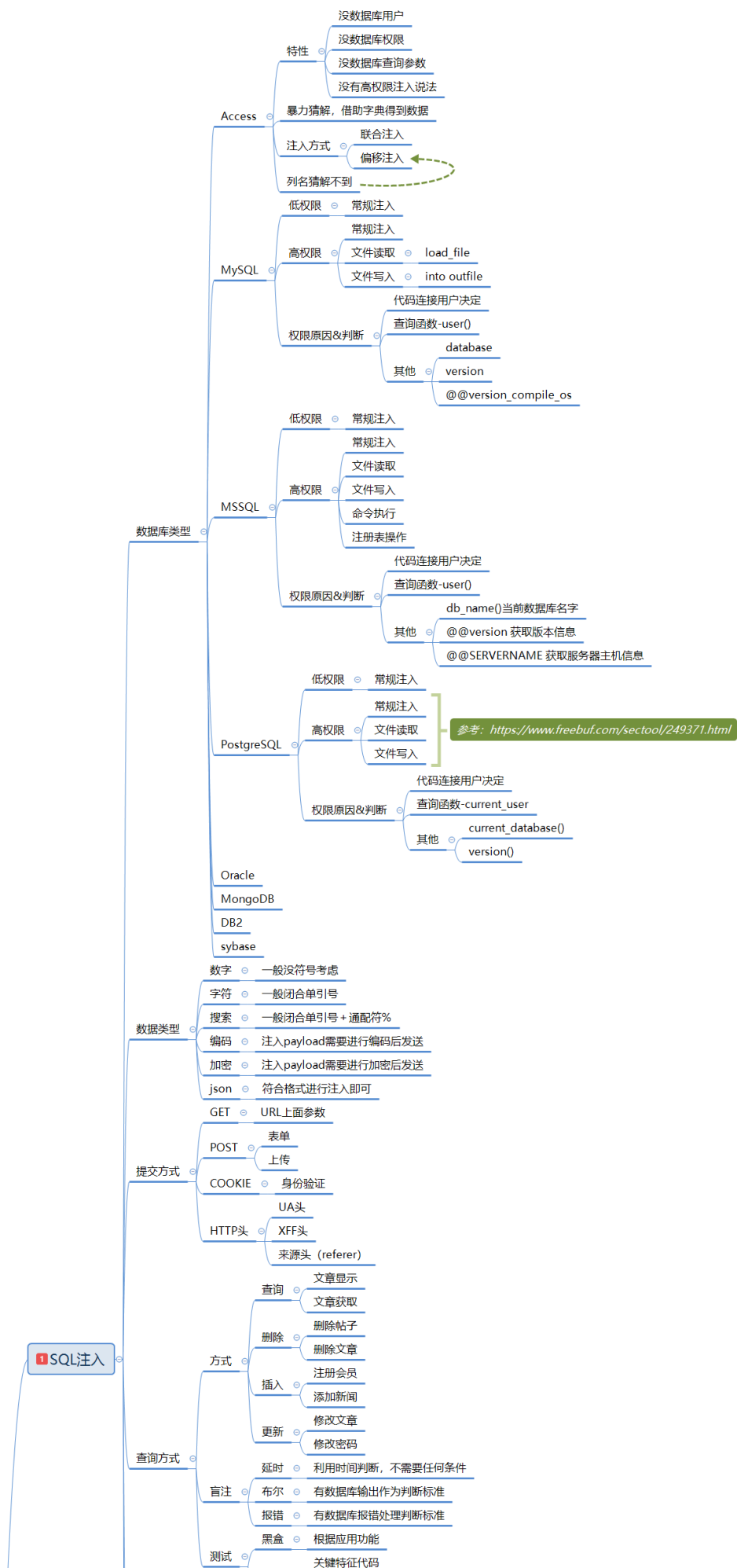
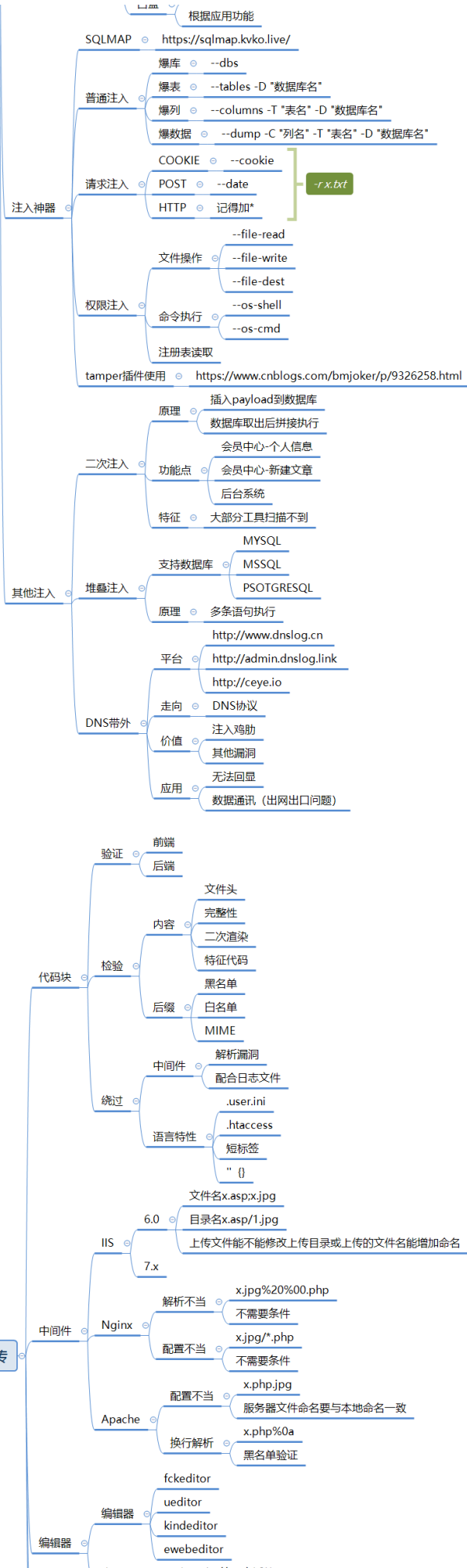
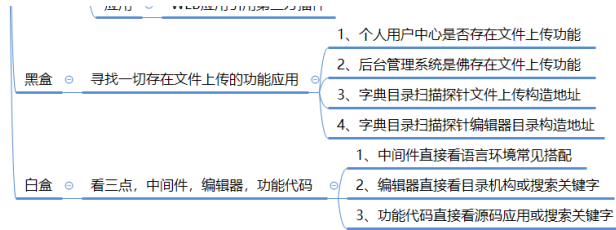


Day76 WEB攻防-Fuzz模糊测试篇&JS算法口令&隐藏参数&盲Payload&未知文件目录



2 文件上传





通用安全漏洞

4 CSRF

-
- ```

graph LR
 Root[CSRF攻击原理] --- C[条件]
 Root --- PD[探针且防御]
 Root --- F[流程]
 Root --- A[审计]

 C --- C1[1、目标用户已经登录了网站，能够执行网站的功能。]
 C --- C2[2、目标用户访问了攻击者构造的 URL。]

 PD --- PD1[1、看验证来源不-修复]
 PD --- PD2[2、看凭证有无 token-修复]
 PD --- PD3[3、看关键操作有无验证-修复]

 F --- F1[1、获取目标的触发数据包]
 F --- F2[2、利用 CSRFTester 构造导出]
 F --- F3[3、诱使受害者访问特定地址触发]

 A --- A1[审计]

```
- 条件**
- 1、目标用户已经登录了网站，能够执行网站的功能。
  - 2、目标用户访问了攻击者构造的 URL。
- 探针且防御**
- 1、看验证来源不-修复
  - 2、看凭证有无 token-修复
  - 3、看关键操作有无验证-修复
- 流程**
- 1、获取目标的触发数据包
  - 2、利用 CSRFTester 构造导出
  - 3、诱使受害者访问特定地址触发
- 审计**

## 5 SSRF

- 条件
  - 当前功能应用点利用服务器去解析拟提交的资源
- 功能
  - 分享
  - 转码
  - 翻译
  - 图片加载
  - 收藏
  - 信息探针
  - 内网扫描

|        | PHP                     | Java              | out                     | Perl           | ASP.NET             |
|--------|-------------------------|-------------------|-------------------------|----------------|---------------------|
| http   | ✓                       | ✓                 | ✓                       | ✓              | ✓                   |
| socket | with<br>cURL extensions | before<br>JDK 1.7 | before 7.4.0 不支<br>持NIO | ✓              | before<br>version 3 |
| ftp    | with<br>cURL extensions | ✓                 | before 7.4.0 不支<br>持NIO | ✓              | ✓                   |
| db     | ✓                       | ✓                 | ✓                       | ✓              | ✓                   |
| dbcp   | ✓                       | ✓                 | ✓                       | ✓              | ✓                   |
| imap   | with<br>cURL extensions | ✓                 | ✓                       | ✓              | ✓                   |
| soap   | with<br>cURL extensions | ✓                 | ✓                       | ✓              | ✓                   |
| xml    | with<br>cURL extensions | ✓                 | ✓                       | ✓              | ✓                   |
| smtp   | with<br>cURL extensions | ✓                 | ✓                       | ✓              | ✓                   |
| telnet | with<br>cURL extensions | ✓                 | ✓                       | ✓              | ✓                   |
| url    | 支持<br>allow_url_fopen   | ✓                 | ✓                       | 支持<br>url.open | ✓                   |
| mail   | 支持<br>allow_url_fopen   | ✓                 | ✓                       | 支持<br>url.open | ✓                   |
| upload | 支持<br>allow_url_fopen   | ✓                 | ✓                       | 支持<br>url.open | ✓                   |
| ftp    | 支持<br>allow_url_fopen   | ✓                 | ✓                       | 支持<br>url.open | ✓                   |

- 探针且防御 ○ SSRF常见安全修复防御方案: ○

  - 1、禁用跳转
  - 2、禁用不需要的协议
  - 3、固定或限制资源地址
  - 4、错误信息统一信息处理

- ```

graph LR
    A[审计] --- B[SSRF白盒可能出现的地方]
    A --- C[SSRF黑盒可能出现的地方]
    B --- B1[1. 功能点抓包指向代码块审计]
    B --- B2[2. 功能点函数定位代码块审计]
    C --- C1[1. 社交分享功能]
    C --- C2[2. 转码服务]
    C --- C3[3. 在线翻译]
    C --- C4[4. 图片加载/下载]
    C --- C5[5. 图片/文章收藏功能]
    C --- C6[6. 云服务厂商]
    C --- C7[7. 网站采集, 网站抓取的地方]
    C --- C8[8. 数据库内置功能]
    C --- C9[9. 邮件系统]
    C --- C10[10. 编码处理, 属性信息处理, 文件处理]
    C --- C11[11. 未公开的api实现以及其他扩展调用URL的功能]
    C --- C12[12. 从远程服务器请求资源]
  
```

6 XXE&XML

- ```

graph LR
 Root[XML 漏洞] --- 前置[前置]
 Root --- 探针[探针]
 Root --- 利用[利用]
 Root --- 修复[修复]

 前置 --- 缘由[缘由：传输和存储数据]
 前置 --- 危害[危害：文件读取，端口探针等]

 探针 --- Content-Type[Content-Type]
 探针 --- 黑盒[黑盒]
 探针 --- 白盒[白盒]

 黑盒 --- 数据格式[数据格式]
 黑盒 --- svg_excel[svg&excel引用]

 白盒 --- 1[1、可通过应用功能追踪代码定位审计]
 白盒 --- 2[2、可通过脚本特定函数搜索定位审计]
 白盒 --- 3[3、可通过伪协议玩法绕过相关修复等]

 利用 --- 有回显[有回显]
 利用 --- 无回显[无回显]
 利用 --- 伪协议[伪协议玩法]

 有回显 --- file_read[file读取文件]
 有回显 --- http_out[http带外访问]

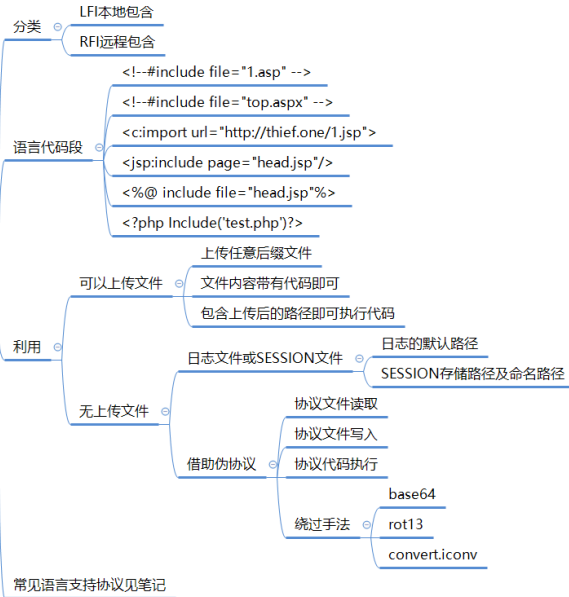
 无回显 --- file_read_pre[file读取文件-先读取]
 无回显 --- http_out_load[http带外访问-加载实体]
 无回显 --- dtd_out_load[dtd带外访问-将数据参数发送接收文件接收数据处理]

 伪协议 --- 见笔记[见笔记图，后期文件包含会讲]

 修复 --- 禁用_dtd[禁用dtd实体引用]
 修复 --- 过滤关键词[过滤关键词：<!DOCTYPE和<!ENTITY，或者SYSTEM和PUBLIC]

```

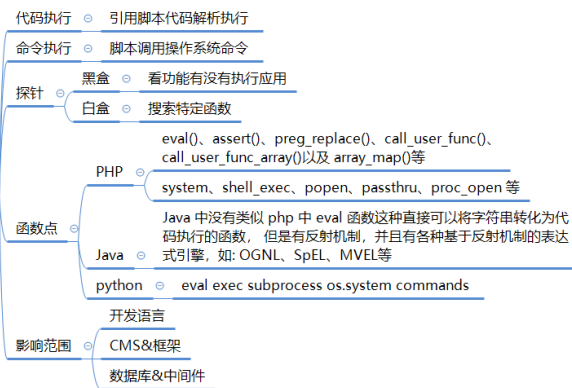
## 文件包含



## 其他文件操作安全



## RCE



## PHP



## 反序列化

### JAVA

#### 属性

- `__toString()`: 把类当做字符串使用时触发
- `__sleep()`: `serialize()`函数会检查类中是否存在一个魔术方法 `__sleep()` 如果存在, 该方法会被优先调用
- `public` (公共的): 在本类内部、外部类、子类都可以访问
- `protect` (受保护的): 只有本类或子类或父类中可以访问
- `private` (私人的): 只有本类内部可以使用
  - 序列化数据显式:
    - `private` 属性序列化的时候格式是 `%00 类名%00 成员名`
    - `protect` 属性序列化的时候格式是 `%00*%00 成员名`

#### 利用

- 单纯的魔术方法逻辑调用
- PHP语言的特性漏洞-如 CVE-2016-7124
- 魔术方法内置原生类
  - 1、获取魔术方法对应原生类
  - 2、利用原生类官方说明配合
- 字符串逃逸&Phar
  - 后面专题讲到

#### 原理

- 序列化: 把 Java 对象转换为字节序列的过程。
- 反序列化: 把字节序列恢复为 Java 对象的过程。

#### 发现

- Serializable Externalizable 接口、fastjson、jackson、gson、ObjectInputStream.read、ObjectObjectInputStream.readUnshared、XMLDecoder.read、ObjectYaml.loadXStream.fromXML、ObjectMapper.readValue、JSON.parseObject 等
- 功能
  - http参数, cookie, session, 存储方式可能是base64(r00), 压缩后的base64(H4s), MII等。Servlets http, Sockets, Session管理器, 包含的协议就包括JMX, RMI, JMS, JNDI等(\xac \xed)\xmlstream.XmlEncoder等(http Body:Content-type: application/xml) json(jacksonfastjson)http请求中包含
- 数据特性
  - 一段数据以 r00AB 开头, 你基本可以确定这串就是 JAVA 序列化 base64 加密的数据。
  - 或者如果以 aced 开头, 那么他就是这一段 java 序列化的 16 进制。

#### 利用

- Ysoserial
  - 无组件
  - 有组件
- 特定的组件利用
  - shiro
  - jboos

### Python

#### 解释

- 文件&字符串&字节流&对象相互转换的过程

#### 原理

- 序列化调用魔术方法
- 反序列化调用魔术方法

#### 函数&魔术方法

- 函数使用:
  - `pickle.dump(obj, file)`: 将对象序列化后保存到文件
  - `pickle.load(file)`: 读取文件, 将文件中的序列化内容反序列化为对象
  - `pickle.dumps(obj)`: 将对象序列化成字符串格式的字节流
  - `pickle.loads(bytes_obj)`: 将字符串格式的字节流反序列化为对象
- 魔术方法:
  - `__reduce__()` 反序列化时调用
  - `__reduce_ex__()` 反序列化时调用
  - `__setstate__()` 反序列化时调用
  - `__getstate__()` 序列化时调用

#### 利用

- 注意当前构造版本和目标版本对应
- 注意当前是否需要编码、转换等

#### 白盒

- 搜索特定函数
- 使用bandit

### 访问权限

#### 越权

- 水平同级用户
  - 用户信息获取时未对用户与 ID 比较判断直接查询等
- 垂直低高用户
  - 数据库中用户类型编号接受篡改或高权限操作未验证等

#### 访问控制

- 验证丢失
  - 未包含引用验证代码文件等
- 没有验证
  - 支持空口令、匿名、白名单等

#### 脆弱验证

- Cookie
  - JWT
  - Session
- 不安全的验证逻辑等

### 购买支付

#### 安全点

- 价格和数量
- 产品和订单编号
- 支付模式&接口数据
- 折扣优惠券积分等重复使用&再获取

#### 安全问题

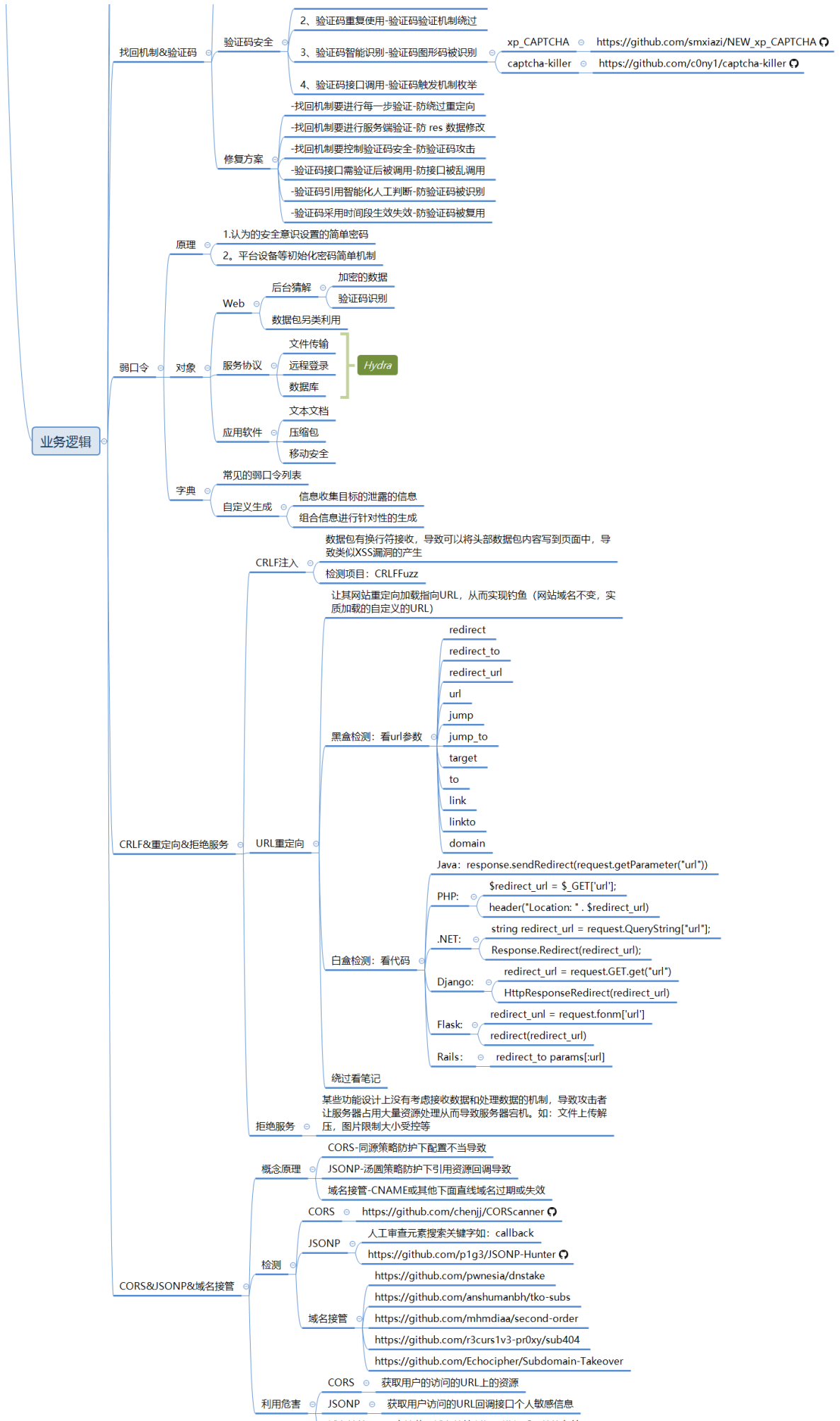
- 1、商品购买-数量&价格&编号等
- 2、支付模式-状态&接口&负数等
- 3、折扣处理-优惠券&积分&重放等

#### 挖掘&修复

- 1、金额以数据库定义为准
  - 2、购买数量限制为正整数
  - 3、优惠券固定使用后删除
  - 4、订单生成后检测对应值
- 功能点抓包造代码测试

#### 找回机制

- 1、用回显状态判断-res 前端判断不安全
- 2、用用户名重定向-修改标示绕过验证
- 3、验证码回显显示-验证码泄漏验证虚设
- 4、验证码简单机制-验证码过于简单爆破





## 1.知识点

- 1、ASP-SQL注入-Access数据库
- 2、ASP-默认安装-数据库泄漏下载
- 3、ASP-IIS-CVE&短文件&解析&写入

- 
- 1、PHP-MYSQL-SQL注入-常规查询
  - 2、PHP-MYSQL-SQL注入-跨库查询
  - 3、PHP-MYSQL-SQL注入-文件读写

- 
- 1、PHP-MYSQL-SQL注入-数据请求类型
  - 2、PHP-MYSQL-SQL注入-数据请求方法
  - 3、PHP-MYSQL-SQL注入-数据请求格式

- 
- 1、PHP-MYSQL-SQL注入-方式增删改查
  - 2、PHP-MYSQL-SQL注入-布尔&延迟&报错
  - 3、PHP-MYSQL-SQL注入-数据回显&报错处理

- 
- 1、PHP-MYSQL-SQL注入-二次注入&利用条件
  - 2、PHP-MYSQL-SQL注入-堆叠注入&利用条件
  - 3、PHP-MYSQL-SQL注入-带外注入&利用条件

- 
- 1、注入工具-SQLMAP-常规猜解&字典配置
  - 2、注入工具-SQLMAP-权限操作&文件命令
  - 3、注入工具-SQLMAP-Tamper&使用&开发
  - 4、注入工具-SQLMAP-调试指纹&风险等级

- 
- 1、PHP-原生态-文件上传-检测后缀&黑白名单
  - 2、PHP-原生态-文件上传-检测信息&类型内容
  - 3、PHP-原生态-文件上传-函数缺陷&逻辑缺陷
  - 4、PHP-原生态-文件上传-版本缺陷&配置缺陷

- 
- 1、PHP-中间件-文件上传-CVE&配置解析
  - 2、PHP-编辑器-文件上传-第三方引用安全

- 3、PHP-CMS源码-文件上传-已知识别到利用

- 
- 1、文件上传-安全解析方案-目录权限&解码还原
  - 2、文件上传-安全存储方案-分站存储&OSS对象

- 
- 1、文件包含-原理&分类&危害-LFI&RFI
  - 2、文件包含-利用-黑白盒&无文件&伪协议

- 
- 1、文件安全-前后台功能点-下载&读取&删除
  - 2、目录安全-前后台功能点-目录遍历&目录穿越

- 
- 1、XSS跨站-输入输出-原理&分类&闭合
  - 2、XSS跨站-分类测试-反射&存储&DOM

- 
- 1、XSS跨站-MXSS&UXSS
  - 2、XSS跨站-SVG制作&配合上传
  - 3、XSS跨站-PDF制作&配合上传
  - 4、XSS跨站-SWF制作&反编译&上传

- 
- 1、XSS跨站-攻击利用-凭据盗取
  - 2、XSS跨站-攻击利用-数据提交
  - 3、XSS跨站-攻击利用-网络钓鱼
  - 4、XSS跨站-攻击利用-溯源综合

- 
- 1、XSS跨站-安全防护-CSP策略
  - 2、XSS跨站-安全防护-HttpOnly
  - 3、XSS跨站-安全防护-XSSFilter

- 
- 1、CSRF-原理&检测&利用&防御
  - 2、CSRF-防御-Referer策略隐患
  - 3、CSRF-防御-Token校验策略隐患

- 
- 1、SSRF-原理-外部资源加载
  - 2、SSRF-利用-伪协议&无回显

- 3、SSRF-挖掘-业务功能&URL参数

- 
- 1、RCE-原理-代码执行&命令执行
  - 2、RCE-黑白盒-过滤绕过&不回显方案

- 
- 1、XXE&XML-原理-用途&外实体&安全
  - 2、XXE&XML-黑盒-格式类型&数据类型
  - 3、XXE&XML-白盒-函数审计&回显方案

- 
- 1、PHP-反序列化-应用&识别&函数
  - 2、PHP-反序列化-魔术方法&触发规则
  - 3、PHP-反序列化-联合漏洞&POP链构造

- 
- 1、PHP-反序列化-属性类型&显示特征
  - 2、PHP-反序列化-CVE绕过&字符串逃逸
  - 3、PHP-反序列化-原生类生成&利用&配合

- 
- 1、PHP-反序列化-开发框架类项目
  - 2、PHP-反序列化-Payload生成项目
  - 3、PHP-反序列化-Payload生成综合项目

- 
- 1、JavaScript-作用域&调用堆栈
  - 2、JavaScript-断点调试&全局搜索
  - 3、JavaScript-Burp算法模块使用

- 
- 1、JavaScript-反调试&方法&绕过
  - 2、JavaScript-代码混淆&识别&还原

- 
- 1、JavaScript安全-泄漏配置信息
  - 2、JavaScript安全-获取接口测试
  - 3、JavaScript安全-代码逻辑分析
  - 4、JavaScript安全-框架漏洞检测

- 
- 1、Java安全-SQL注入-JDBC&MyBatis

- 2、Java安全-XXE注入-Reader&Builder
  - 3、Java安全-SSTI模版-Thymeleaf&URL
  - 4、Java安全-SPEL表达式-SpringBoot框架
- 

- 1、Java安全-RCE执行-5大类函数调用
  - 2、Java安全-JNDI注入-RMI&LDAP&高版本
  - 3、Java安全-不安全组件-Shiro&FastJson&Jackson&XStream&Log4j
- 

- 1、Java安全-原生反序列化-3大类接口函数&利用
  - 2、Java安全-SpringBoot攻防-泄漏安全&CVE安全
- 

- 1、Java安全-Druid监控-未授权访问&信息泄漏
  - 2、Java安全-Swagger接口-文档导入&联动批量测试
  - 2、Java安全-JWT令牌攻防-空算法&未签名&密钥提取
- 

- 1、Python安全-SSTI注入-类型&形成&利用&项目
- 

- 1、Python-PYC-反编译文件出源码
  - 2、Python-反序列化-调用链&魔术方法
  - 3、Python-格式化字符串-类魔术方法引用
- 

- 1、逻辑越权-检测原理-水平&垂直&未授权
  - 2、逻辑越权-检测项目-BURP插件&对比项目
  - 3、SRC挖掘-实战越权及未授权挖掘分享案例
- 

- 1、支付逻辑-商品本身-修改-数量&价格&属性等
  - 2、支付逻辑-营销折扣-优惠券&积分&签约&试用等
  - 3、支付逻辑-订单接口-替换&并发&状态值&越权支付等
- 

- 1、找回修改机制-验证码突破-回传显示&规律爆破
  - 2、找回修改机制-验证目标-重定向用户&重定向发送
  - 3、找回修改机制-验证逻辑-修改响应包&跳过步骤URL
- 

- 1、验证码简单机制-验证码过于简单可爆破

- 2、验证码重复使用-验证码验证机制可绕过
  - 3、验证码智能识别-验证码图形码被可识别
  - 4、验证码接口调用-验证码触发接口可枚举
- 

- 1、Fuzz技术应用-用户口令(弱口令)
- 2、Fuzz技术应用-目录文件(泄漏点)
- 3、Fuzz技术应用-未知参数(利用参数)
- 4、Fuzz技术应用-Payload(Bypass)

## 2.演示案例

```
1 1、Fuzz
2 是一种基于黑盒的自动化软件模糊测试技术,简单的说一种懒惰且暴力的技术融合了常见的以及精心构建的数据文本进行网站、软件安全性测试。
3
4 2、Fuzz的核心思想:
5 口令Fuzz(弱口令)
6 目录Fuzz(漏洞点)
7 参数Fuzz(利用参数)
8 PayloadFuzz(Bypass)
9
10 3、Fuzz应用场景:
11 -爆破用户口令
12 -爆破敏感目录
13 -爆破文件地址
14 -爆破未知参数名
15 -Payload测漏洞(绕过等也可以用)
16 在实战黑盒中,目标有很多没有显示或其他工具扫描不到的文件或目录等,我们就可以通过大量的字典Fuzz找到的隐藏的文件进行测试。
17
18 4、Fuzz项目:
19 https://github.com/fuzzdb-project/fuzzdb
20 https://github.com/TheKingOfDuck/fuzzDicts
21 https://github.com/danielmiessler/SecLists
```

### 2.1 Fuzz技术-用户口令-常规&模块&JS插件

```
1 https://github.com/c0ny1/jsEncrypter
2 https://github.com/whwlsfb/BurpCrypto
```

## 2.2 Fuzz技术-目录文件-目录探针&文件探针

## 2.3 Fuzz技术-未知参数名-文件参数&隐藏参数

## 2.4 fuzz技术-构造参数值-漏洞攻击恶意Payload

## 2.5 Fuzz技术SRC泄漏未授权案例挖掘



1 参考课件。